

CORPORACIÓN UNIVERSITARIA MINUTO DE DIOS – UNIMINUTO

Rectoría UNIMINUTO Virtual

Evaluación de la calidad del software mediante métricas, verificación y auditoría

Caso MediCitas v3.2 – IPS Salud Total

Reporte de solución de problemas matemáticos

Kevin Nicolás Buenaventura Ramírez

ID estudiantil: 432270

Estándares y Métricas de Calidad en el Desarrollo de Software

NRC-93980 — Semana 2

Docente: Cesar Alfonso Bolado Silva

Bogotá D.C., 11 de julio de 2026

Tabla de contenido

Tabla de contenido	2
Introducción	3
1. Análisis del escenario	3
2. Metodología y procedimiento de análisis	4
3. Identificación y justificación de hallazgos de seguridad	4
4. Actividades de verificación y validación aplicables al escenario	5
5. Lista de verificación de revisión técnica	7
6. Plan de auditoría	8
6.1 Datos generales	8
6.2 Hallazgos de auditoría	8
6.3 Conclusión de la auditoría	9
7. Selección y aplicación del estándar ISO/IEC 25010	9
8. Definición de métricas de calidad	9
9. Conclusiones y recomendaciones priorizadas	10
10. Aplicación al contexto profesional del autor	11
Referencias	13

Introducción

El presente reporte desarrolla un ejercicio de aseguramiento de la calidad del software aplicado al sistema MediCitas, la plataforma de información de la IPS Salud Total, en el marco de la preparación de su versión 3.2 previa a la liberación a producción. El objetivo del trabajo es asumir el rol de especialista en aseguramiento de la calidad (QA) y, a partir de la evidencia disponible (especificación de requisitos, bitácora de incidencias, control de cambios y resultados de pruebas preliminares), determinar si el sistema se encuentra en condiciones de ser liberado, identificando los riesgos que deben resolverse antes de dicha liberación.

Para lograrlo, se aplican de manera articulada los cuatro pilares del aseguramiento de la calidad estudiados durante la semana: la verificación y la validación, las revisiones técnicas, las auditorías y el uso de estándares y métricas de calidad, tomando como referencia principal la norma ISO/IEC 25010 y los lineamientos de la IEEE 1028 para revisiones y auditorías de software. El desarrollo del trabajo incluye la identificación y justificación de hallazgos de seguridad, la construcción de una matriz de verificación y validación, una lista de control de revisión técnica, un plan de auditoría con sus respectivos hallazgos, y un conjunto de métricas de calidad con su fórmula y criterio de aceptación, para finalmente presentar conclusiones y recomendaciones priorizadas dirigidas a la gerencia y al equipo de desarrollo.

Este ejercicio adquiere un valor adicional para el autor, quien se desempeña actualmente como analista del área de soporte y desarrollo en una Administradora de Riesgos Laborales (ARL), donde atiende incidentes que con frecuencia involucran fallas de acceso, inconsistencias de datos y problemas a nivel de base de datos. La sección final de este documento retoma esa experiencia profesional para relacionarla con los hallazgos del caso MediCitas.

1. Análisis del escenario

MediCitas es el sistema de información utilizado por una red de doce clínicas ambulatorias de la IPS Salud Total en Bogotá y municipios cercanos. El sistema soporta procesos misionales de alta sensibilidad: agendamiento de citas, gestión de historias clínicas electrónicas (HCE), emisión de órdenes médicas y recetas, facturación electrónica con integración a la DIAN, notificaciones por SMS y WhatsApp, y próximamente telemedicina. La versión 3.2, que se encuentra en preparación, introduce dos cambios de alto impacto: un módulo de videoconsulta y un mecanismo de autenticación único (SSO) para el personal médico y administrativo.

El contexto organizacional plantea varios factores de riesgo relevantes para el análisis de calidad. El equipo de desarrollo trabaja bajo un esquema ágil de ocho personas, sin un área de aseguramiento de calidad independiente y consolidada, lo cual concentra en el mismo equipo tanto la construcción como el control del producto. A esto se suma una fecha de liberación fijada contractualmente en tres semanas, con el alcance ya congelado, y una presión comercial explícita por lanzar telemedicina antes que la competencia. Estos elementos son relevantes porque, típicamente, la combinación de plazos rígidos, ausencia de QA independiente y presión comercial es un patrón asociado a la reducción de actividades de verificación y validación, tal como se evidencia más adelante en los hallazgos.

Desde el punto de vista regulatorio, el sistema debe cumplir con la Ley 1581 de 2012 y el Decreto 1377 de 2013 sobre protección de datos personales, la Resolución 1995 de 1999 del Ministerio de Salud sobre manejo y custodia de la historia clínica, las Resoluciones 2654 y 3100 de 2019 sobre telesalud, y el estándar PCI-DSS para el procesamiento de pagos. Adicionalmente, se exige una disponibilidad mínima del 99.5 % en el horario de atención y la integración batch nocturna con el sistema legado AS/400. Este marco de restricciones técnicas y normativas constituye, junto con la ISO/IEC 25010, el criterio contra el cual se evalúan los hallazgos identificados en las siguientes secciones.

2. Metodología y procedimiento de análisis

Para resolver el caso se siguió un procedimiento estructurado en seis pasos, coherente con el enfoque de aseguramiento de la calidad revisado en la semana:

- **Análisis del escenario:** se identificaron los actores, las funcionalidades críticas y las restricciones técnicas y regulatorias que delimitan el alcance de la evaluación.
- **Cruce de evidencias:** se contrastó la especificación de requisitos con la bitácora de incidencias, la lista de control de cambios y los resultados de pruebas preliminares, para detectar inconsistencias entre lo requerido y lo efectivamente implementado o verificado.
- **Identificación de hallazgos de seguridad:** a partir del cruce anterior se seleccionaron los hallazgos con mayor impacto sobre la confidencialidad, integridad y trazabilidad de la información.
- **Diligenciamiento de la matriz de verificación y validación:** se clasificó cada requisito o funcionalidad como objeto de verificación (¿se construyó conforme a especificación?) o de validación (¿satisface la necesidad real del usuario?), asignando técnica, responsable y criterio de aceptación.
- **Construcción de la lista de control de revisión técnica y del plan de auditoría:** se evaluó el cumplimiento de cada ítem de la checklist contra la evidencia disponible, y se estructuró un plan de auditoría con sus hallazgos y severidad.
- **Selección de estándar y definición de métricas:** se aplicó la ISO/IEC 25010 para justificar cada hallazgo según la característica de calidad comprometida, y se definieron métricas cuantitativas con su fórmula y criterio de aceptación, que sustentan las conclusiones y recomendaciones finales.

Este procedimiento permite pasar de una evidencia dispersa (requisitos, incidencias, cambios y pruebas) a un juicio de calidad fundamentado, evitando decisiones basadas únicamente en la percepción del equipo de desarrollo o en la presión del cronograma.

3. Identificación y justificación de hallazgos de seguridad

A partir del cruce entre la especificación de requisitos, la bitácora de incidencias y el control de cambios, se identificaron los siguientes seis hallazgos de seguridad, todos con evidencia trazable en el escenario. Se presentan en orden de aparición en la bitácora, y su priorización por severidad se retoma en el plan de auditoría y en las conclusiones.

N.º	Hallazgo	Evidencia	Justificación e impacto
1	Control de acceso roto (IDOR) en historias clínicas	INC-101	Un médico accedió a historias clínicas de pacientes que no tenía asignados, simplemente alterando el identificador en la URL del navegador. Esto indica que el sistema no valida la autorización a nivel de objeto en el backend, sino que confía en un parámetro enviado por el cliente. El impacto es alto: se compromete la confidencialidad de datos clínicos protegidos por la Resolución 1995 de 1999 y la Ley 1581 de 2012, con riesgo legal, sancionatorio y reputacional para la IPS.
2	Cuentas administrativas compartidas sin expiración	INC-102	La cuenta "admin_ti" es utilizada por cuatro personas del equipo de soporte y sus contraseñas no expiran. Esto elimina la trazabilidad y el no repudio de las acciones administrativas: ante un incidente, no es posible determinar qué persona ejecutó una acción específica. Además, al no expirar las credenciales, aumenta la ventana de exposición ante una eventual fuga de contraseña.
3	Canal de videoconsulta transmitido sin cifrar	INC-103 / CR-202	Una configuración de pruebas del servidor de video pasó a producción sin ser detectada, dejando el canal de telemedicina operando sobre HTTP en lugar de un protocolo cifrado. El hallazgo evidencia una falla doble: de seguridad (datos de salud viajando en texto plano) y de proceso de control de cambios, dado que el cambio se desplegó sin revisión registrada, incumpliendo el requisito RF-060 y la Resolución 2654 de 2019 sobre telesalud.
4	Registro sin enmascarar del número de tarjeta en pagos	INC-104	Los logs de la pasarela de pagos PayGateCol almacenan el número completo de la tarjeta sin enmascarar ni tokenizar. Esto constituye un incumplimiento directo del estándar PCI-DSS, que exige explícitamente no almacenar el número completo de tarjeta (PAN) en registros. El impacto incluye riesgo de fraude financiero para los pacientes y posible sanción contractual con el proveedor de la pasarela.
5	Ausencia de registro de lecturas en la historia clínica	INC-105 / RF-045	El sistema únicamente registra las escrituras (modificaciones) sobre la historia clínica, pero no las lecturas. Esto significa que un acceso indebido como el descrito en el hallazgo 1 (INC-101) no habría podido detectarse ni auditarse posteriormente, ya que no queda evidencia de quién consultó una historia clínica sin estar autorizado. Se incumple el requisito RF-045 y la trazabilidad exigida por la Resolución 1995 de 1999.
6	Pruebas críticas de seguridad y carga no ejecutadas	Resultados de pruebas preliminares	El pentesting de la historia clínica electrónica no se ejecutó por falta de tiempo en el cronograma, y la prueba de carga del módulo de agendamiento (100 usuarios concurrentes) tampoco se realizó. A tres semanas de la liberación contractual, esto implica que el sistema podría llegar a producción sin haber confirmado su resistencia a ataques ni su comportamiento bajo carga real, lo que constituye un riesgo operativo adicional a los hallazgos puntuales anteriores.

4. Actividades de verificación y validación aplicables al escenario

Verificación: consiste en confirmar que el producto se está construyendo conforme a las especificaciones, en cada etapa del ciclo de vida. Responde a la pregunta "¿estamos construyendo el producto correctamente?" y se

apoya en técnicas estáticas como revisión de código, inspección de configuración e inspección de logs, aplicadas por el propio equipo de desarrollo y de calidad.

Validación: confirma que el producto satisface las necesidades reales del usuario y del negocio, respondiendo a la pregunta "¿estamos construyendo el producto correcto?". Se apoya en técnicas dinámicas —pruebas de carga, pruebas de aceptación, pruebas piloto— ejecutadas sobre el sistema en funcionamiento.

En el caso de MediCitas, ambas actividades deben aplicarse de forma complementaria: mientras la verificación permite confirmar que el cifrado, la trazabilidad y el cumplimiento normativo están correctamente implementados a nivel de código y configuración, la validación permite confirmar que funcionalidades como el SSO, la videoconsulta o el rendimiento del agendamiento realmente funcionan de forma aceptable para los usuarios finales bajo condiciones reales. La siguiente matriz relaciona los requisitos y funcionalidades críticas del escenario con el tipo de actividad, la técnica, el responsable y el criterio de aceptación correspondiente.

ID	Requisito / funcionalidad	Tipo	Técnica y responsable	Criterio de aceptación
RF-022	Cifrado de la HCE en reposo (AES-256)	Verificación	Revisión de configuración de cifrado e inspección de la base de datos — Administrador de TI/DBA	Todos los campos de datos clínicos deben estar cifrados con AES-256
RF-031	Rendimiento del agendamiento bajo carga	Validación	Prueba de carga con 100 usuarios concurrentes — Equipo de pruebas	Tiempo de respuesta ≤ 2 segundos en el percentil 95
RF-045	Trazabilidad de accesos a la HCE (lectura y escritura)	Verificación	Inspección de logs y revisión del mecanismo de auditoría — Líder técnico	Todo acceso de lectura y escritura queda registrado de forma inmutable
RF-052	Cumplimiento PCI-DSS en el módulo de pagos	Verificación	Auditoría de cumplimiento PCI-DSS — Oficial de protección de datos / auditor externo	Cero campos con número completo de tarjeta (PAN) en logs o base de datos
RF-060	Cifrado extremo a extremo del canal de video	Verificación	Revisión de configuración TLS/SRTP del servidor de videoconferencia — Administrador de TI	El canal se sirve siempre sobre HTTPS/SRTP, nunca sobre HTTP
CR-201	Autenticación única (SSO) para personal médico y administrativo	Validación	Prueba de aceptación con usuarios piloto — Product Owner	Inicio de sesión único funcional en los tres roles, sin bloqueos
INC-101	Control de acceso por rol a la historia clínica	Verificación	Inspección de código y prueba de penetración dirigida (IDOR) — Equipo de pruebas de seguridad	Ningún usuario accede a historias clínicas de pacientes no asignados
INC-106	Integración batch nocturna con el sistema AS/400	Validación	Prueba de integración y monitoreo de alertas — Administrador de TI/DBA	Cero fallos sin alerta en cuatro semanas de observación
—	Experiencia de usuario en el módulo de telemedicina	Validación	Prueba piloto con pacientes y personal médico — Product Owner	Videoconsulta estable y cifrada; satisfacción igual o superior al 90 % en la encuesta piloto

5. Lista de verificación de revisión técnica

Con base en el estándar IEEE 1028 para revisiones de software, se construyó la siguiente lista de control de catorce ítems, aplicada sobre el escenario de MediCitas v3.2. Cada ítem se contrastó con la evidencia disponible (requisitos, bitácora de incidencias, control de cambios y resultados de pruebas) para determinar su cumplimiento.

N.º	Ítem de revisión	Cumple	Observaciones / evidencia
1	El código fuente cumple los estándares de codificación definidos por el equipo.	N.A.	El escenario no aporta evidencia sobre estándares de codificación del equipo.
2	Existe trazabilidad entre los requisitos y los casos de prueba ejecutados.	No	RF-031 y RF-060 no cuentan con casos de prueba ejecutados según los resultados preliminares.
3	Todos los cambios fueron documentados y aprobados antes de su despliegue a producción.	No	CR-202 y CR-205 se desplegaron sin revisión registrada.
4	Los mecanismos de autenticación y autorización protegen adecuadamente los recursos críticos.	No	INC-101 evidencia una falla de control de acceso (IDOR); el 2FA es opcional (RF-014).
5	La información sensible (datos clínicos, financieros) se almacena y transmite cifrada.	No	RF-022 pendiente de verificación; el canal de video se transmitió sin cifrar (INC-103).
6	Existen registros de auditoría (logs) para accesos y modificaciones a información crítica.	No	Solo se registran escrituras sobre la HCE, no lecturas (INC-105).
7	Se ejecutaron pruebas de seguridad (pentesting) antes de la liberación.	No	El pentesting de la HCE no se ejecutó por falta de tiempo asignado en el cronograma.
8	Se ejecutaron pruebas de carga o rendimiento sobre los módulos críticos.	No	RF-031 no fue probado bajo carga; la prueba de carga de telemedicina tampoco se ejecutó.
9	El manejo de datos personales cumple con la Ley 1581 de 2012 y su reglamentación.	No	INC-101, INC-102 y RF-022 pendiente evidencian brechas en la protección de datos.
10	El manejo de la historia clínica cumple con la Resolución 1995 de 1999.	No	Falta de registro de lecturas (INC-105) y acceso indebido detectado (INC-101).
11	El módulo de telemedicina cumple con las disposiciones de la Resolución 2654 de 2019.	No	El canal sin cifrar (INC-103) incumple las condiciones de seguridad exigidas para telesalud.
12	Existen alertas automáticas ante fallos de procesos críticos.	No	El proceso batch de facturación falló tres veces en cuatro semanas sin generar alerta (INC-106).
13	La documentación técnica y de usuario está actualizada para la versión a liberar.	N.A.	El escenario no aporta evidencia al respecto; debe verificarse antes de la liberación.
14	Los riesgos técnicos y regulatorios identificados fueron mitigados antes de la liberación.	No	Persisten cinco hallazgos de seguridad abiertos y pruebas críticas sin ejecutar, a solo tres semanas del release.

El resultado de la revisión técnica es contundente: de los catorce ítems evaluados, once no se cumplen y dos no cuentan con evidencia suficiente en el escenario para ser calificados (N.A.). Ningún ítem relacionado con seguridad, trazabilidad o cumplimiento normativo se cumple plenamente, lo cual constituye una señal de alerta temprana antes de avanzar hacia la etapa de auditoría formal.

6. Plan de auditoría

6.1 Datos generales

Campo	Contenido
Objetivo de la auditoría	Evaluar el cumplimiento de MediCitas v3.2 con los requisitos de seguridad, protección de datos y regulación de telesalud aplicables, antes de su liberación a producción.
Alcance	Módulos de autenticación (SSO), historia clínica electrónica, telemedicina, pagos y facturación (integración AS/400); evidencia correspondiente a los dos últimos meses.
Criterios de auditoría	ISO/IEC 25010; Ley 1581 de 2012 y Decreto 1377 de 2013; Resolución 1995 de 1999; Resoluciones 2654 y 3100 de 2019; estándar PCI-DSS.
Equipo auditor	Auditor líder externo, independiente del equipo Scrum; oficial de protección de datos; especialista en seguridad de la información.
Fecha de ejecución	Dentro de las tres semanas previas a la liberación contractual, preferiblemente en la primera semana, para permitir tiempo de remediación.
Evidencias a recolectar	Bitácora de incidencias (INC-101 a INC-107), lista de control de cambios (CR-201 a CR-205), resultados de pruebas, registros de acceso a la HCE, configuración del canal de video y logs de la pasarela de pagos.

6.2 Hallazgos de auditoría

N.º	Hallazgo	Criterio incumplido	Evidencia	Severidad	Recomendación
1	Control de acceso roto que permite la lectura de historias clínicas de pacientes no asignados (IDOR).	Res. 1995/1999; ISO/IEC 25010 — Seguridad (confidencialidad)	INC-101	Alta	Validar la autorización a nivel de objeto en el backend; no confiar en el identificador recibido del cliente.
2	Cuentas administrativas compartidas, sin expiración de contraseña.	Gestión de identidad; ISO/IEC 25010 — Seguridad (responsabilidad)	INC-102	Alta	Eliminar las cuentas compartidas; asignar cuentas nominales con autenticación multifactor y expiración periódica.
3	Canal de videoconsulta transmitido sin cifrar por un error de despliegue.	Res. 2654/2019; RF-060	INC-103 / CR-202	Alta	Forzar TLS/SRTP en producción; bloquear despliegues sin aprobación registrada.
4	Registros de la pasarela de pagos exponen el número completo de la tarjeta.	PCI-DSS (enmascaramiento del PAN)	INC-104	Alta	Enmascarar o tokenizar el número de tarjeta en todos los logs; revisar la configuración con PayGateCol.
5	No se registran los accesos de lectura a la historia clínica.	RF-045; Res. 1995/1999 (trazabilidad)	INC-105	Media-alta	Extender el log de auditoría inmutable a las operaciones de lectura, con revisión periódica.

6.3 Conclusión de la auditoría

MediCitas v3.2 no se encuentra en condiciones de liberarse a producción en su estado actual. Persisten brechas de seguridad y trazabilidad sin remediar, pruebas críticas de seguridad y desempeño sin ejecutar, y cambios desplegados sin control (CR-202 y CR-205). Se recomienda no liberar los módulos de telemedicina y pagos hasta remediar los hallazgos de severidad alta identificados en la presente auditoría.

7. Selección y aplicación del estándar ISO/IEC 25010

Se seleccionó la norma ISO/IEC 25010:2023 (Systems and software engineering — Systems and software quality requirements and evaluation, SQuaRE) como referencia principal para justificar los hallazgos, por ser el modelo de calidad de producto de software más reconocido y por definir nueve características evaluables —entre ellas adecuación funcional, eficiencia de desempeño, compatibilidad, usabilidad, fiabilidad, seguridad, mantenibilidad, portabilidad y seguridad de operación— con subcaracterísticas medibles que permiten un lenguaje común entre el equipo técnico, la auditoría y la gerencia.

En el caso de MediCitas, la característica más comprometida es la seguridad, particularmente en sus subcaracterísticas de confidencialidad, integridad y responsabilidad (accountability). La tabla siguiente relaciona cada hallazgo con la característica de calidad que compromete y su justificación.

Hallazgo	Característica ISO/IEC 25010	Justificación
Control de acceso roto (IDOR)	Seguridad — Confidencialidad	El sistema no impide que un usuario acceda a datos que no le corresponden.
Cuentas administrativas compartidas	Seguridad — Responsabilidad / autenticidad	No es posible atribuir una acción del sistema a una identidad única.
Canal de video sin cifrar	Seguridad — Confidencialidad e integridad	Los datos de salud viajan expuestos y pueden ser interceptados o alterados en tránsito.
Logs de pago sin enmascarar	Seguridad — Confidencialidad	Se expone información financiera sensible en registros internos del sistema.
Ausencia de log de lectura en la HCE y fallos de batch sin alerta	Fiabilidad — Madurez / tolerancia a fallos	El sistema no detecta ni notifica oportunamente condiciones anómalas de operación.
Pruebas de seguridad y de carga no ejecutadas	Mantenibilidad — Capacidad de prueba	No existe evidencia de que el sistema haya sido verificado en condiciones de estrés o ante intentos de intrusión antes de la liberación.

8. Definición de métricas de calidad

Toda métrica de calidad útil combina una fórmula o forma de medición clara con un criterio de aceptación explícito; de lo contrario, la evaluación de calidad se convierte en una opinión y no en una decisión sustentada en

evidencia. A continuación se definen seis métricas aplicables al caso MediCitas, calculadas con los datos disponibles en el escenario.

Métrica	Fórmula / forma de medición	Cálculo con los datos del caso	Criterio de aceptación
Densidad de hallazgos críticos	N.º de hallazgos de severidad alta / N.º de funcionalidades críticas	5 hallazgos de severidad alta / 8 funcionalidades críticas = 0.63	0 hallazgos de severidad alta abiertos antes del release
Cobertura de pruebas críticas ejecutadas	(Pruebas críticas ejecutadas / total de pruebas críticas planificadas) × 100 %	2 de 4 pruebas críticas ejecutadas (pentesting de HCE y carga de telemedicina no ejecutadas) = 50 %	≥ 100 % de las pruebas críticas ejecutadas antes del release
Tasa de cambios desplegados sin revisión	(Cambios sin revisión registrada / total de cambios) × 100 %	2 de 5 cambios (CR-202 y CR-205) sin revisión registrada = 40 %	0 % de cambios desplegados sin aprobación
Fallos del proceso batch sin alerta	N.º de fallos sin generar alerta automática	3 fallos en 4 semanas sin generar alerta automática (INC-106)	100 % de los fallos deben generar alerta; 0 fallos silenciosos
Disponibilidad en horario de atención	(Horas de operación efectiva / horas de operación programadas) × 100 %	Criterio contractual del 99.5 % (7:00 a. m. a 9:00 p. m.); sin medición formal reportada en el escenario	≥ 99.5 % medido mediante monitoreo continuo
Tasa de cumplimiento de acciones de auditoría	(Hallazgos de auditoría cerrados / hallazgos totales) × 100 %	0 de 5 hallazgos cerrados a la fecha de corte del escenario = 0 %	100 % de los hallazgos de severidad alta cerrados antes de la liberación a producción

9. Conclusiones y recomendaciones priorizadas

El análisis integral del escenario, respaldado por la matriz de verificación y validación, la lista de control de revisión técnica, el plan de auditoría y las métricas calculadas, conduce a una conclusión unánime: el sistema MediCitas, en su versión 3.2, no cumple actualmente las condiciones mínimas de calidad y seguridad para ser liberado a producción. De los catorce ítems de la lista de control, once no se cumplen; cinco hallazgos de severidad alta o media-alta permanecen abiertos; y dos de las cuatro pruebas críticas de seguridad y desempeño no fueron ejecutadas. Estos resultados no son incidentes aislados, sino síntoma de un proceso de aseguramiento de calidad debilitado por la ausencia de un área de QA independiente, un cronograma contractual rígido y presión comercial por adelantar el lanzamiento de la telemedicina.

A partir de estos resultados, se plantean las siguientes recomendaciones, priorizadas según la severidad del riesgo que atienden:

Prioridad crítica

- Corregir el control de acceso a la historia clínica electrónica (falla IDOR) y extender el log de auditoría inmutable a las operaciones de lectura, no solo de escritura.
- Forzar el cifrado del canal de videoconsulta (TLS/SRTP) y enmascarar o tokenizar el número de tarjeta en los registros de la pasarela de pagos; re-ejecutar las pruebas de seguridad correspondientes antes de avanzar.

Prioridad alta

- Eliminar las cuentas administrativas compartidas y exigir autenticación multifactor con expiración periódica de contraseñas para todo el personal técnico.
- Ejecutar el pentesting pendiente sobre la historia clínica electrónica y la prueba de carga del módulo de agendamiento y telemedicina antes de dar por congelado el alcance de la liberación.

Prioridad media

- Formalizar el proceso de control de cambios, de manera que ningún despliegue a producción se realice sin revisión y aprobación registrada, tal como ocurrió con CR-202 y CR-205.
- Implementar alertas automáticas ante fallos del proceso batch de facturación con el sistema AS/400, para evitar que fallas como las registradas en INC-106 pasen desapercibidas.

Dado el número y la severidad de los hallazgos abiertos, la recomendación general para la gerencia de la IPS es evaluar una prórroga de la fecha contractual de liberación, o bien optar por una liberación por fases que excluya inicialmente los módulos de telemedicina y de pagos, hasta que los hallazgos críticos y de prioridad alta hayan sido remediados y verificados. Liberar el sistema en su estado actual expondría a la organización a riesgos legales derivados del incumplimiento de la normativa de protección de datos y de historia clínica, así como a riesgos reputacionales y financieros asociados al incumplimiento de PCI-DSS.

10. Aplicación al contexto profesional del autor

Más allá de su valor académico, el desarrollo de este caso guarda una relación directa con la labor que actualmente desempeño como analista del área de soporte y desarrollo en una Administradora de Riesgos Laborales (ARL), y con el rol de líder de operación de mesa de ayuda al que aspiro en el corto plazo. En mi día a día atiendo requerimientos e incidentes reportados por usuarios internos y externos que, en muchos casos, exigen intervención directa a nivel de base de datos: corrección de registros inconsistentes, depuración de datos duplicados, ajuste de permisos de acceso y diagnóstico de fallas en procesos batch o integraciones entre sistemas. Esta experiencia me permitió reconocer con facilidad, en el caso MediCitas, el tipo de incidentes que normalmente escalan desde una mesa de ayuda de primer nivel hacia soporte técnico y, de allí, hacia el equipo de desarrollo o el administrador de base de datos.

Un ejemplo claro es el hallazgo INC-101, el acceso indebido a historias clínicas mediante la manipulación del identificador en la URL (falla de tipo IDOR). En la operación real de una mesa de ayuda, un caso así normalmente ingresa como un reporte de "un usuario ve información que no le corresponde", y su correcta clasificación como incidente de seguridad —y no como una simple solicitud funcional— es justamente lo que permite escalarlo a

tiempo hacia el equipo de desarrollo y evitar que se repita. De la misma manera, el hallazgo INC-106, sobre fallos silenciosos del proceso batch de integración con el sistema AS/400, es equivalente a los procesos nocturnos de cargue e interfaces que superviso en mi rol actual: cuando un proceso de este tipo falla sin generar alerta, la mesa de ayuda se entera únicamente cuando el usuario reporta el problema al día siguiente, lo cual retrasa la solución y aumenta el impacto sobre el negocio. Por ello, la recomendación de implementar alertas automáticas ante fallos de procesos críticos, planteada en la sección de conclusiones, es una práctica que ya considero indispensable en la gestión de incidentes de mi área.

Asimismo, la lista de control de cambios del caso (CR-201 a CR-205), y en particular los dos cambios desplegados sin revisión registrada (CR-202 y CR-205), reflejan un riesgo que también se presenta con frecuencia en entornos de soporte y desarrollo: la ausencia de un proceso formal de control de cambios facilita que ajustes de configuración —como el que dejó el canal de video sin cifrar— lleguen a producción sin la validación adecuada. En mi experiencia, contar con una matriz de verificación y validación, una lista de control de revisiones y un plan de auditoría, como los desarrollados en este trabajo, no son solamente herramientas académicas: son instrumentos que un futuro líder de operación de mesa de ayuda puede adaptar directamente para estructurar la gestión de incidentes, problemas y cambios de su equipo, alineándose con buenas prácticas de marcos como ITIL.

En este sentido, el ejercicio desarrollado en el presente documento no solo responde a los objetivos de la asignatura de Estándares y Métricas de Calidad en el Desarrollo de Software, sino que fortalece de manera concreta las competencias que busco consolidar en mi trayectoria profesional: la capacidad de identificar riesgos de calidad y seguridad desde la evidencia operativa, de traducir hallazgos técnicos —incluidos aquellos con causa raíz en base de datos— en recomendaciones priorizadas, y de estructurar procesos de revisión y auditoría que sustenten decisiones informadas de liberación de software, todas ellas competencias centrales para la gestión de una mesa de ayuda y de un equipo de soporte y desarrollo.

Referencias

- Chavarría, A., Oré, S., & Pastor, C. (2016). Aseguramiento de la calidad en el proceso de desarrollo de software utilizando CMMI, TSP y PSP. *Revista Ibérica de Sistemas e Tecnologías de Informação*, (20), 62–77. <http://dx.doi.org/10.17013/risti.20.62-77>
- Institute of Electrical and Electronics Engineers. (2008). IEEE Std 1028-2008: IEEE standard for software reviews and audits. IEEE.
- Institute of Electrical and Electronics Engineers. (2014). IEEE Std 730-2014: IEEE standard for software quality assurance processes. IEEE.
- International Organization for Standardization. (2023). ISO/IEC 25010:2023 — Systems and software engineering — Systems and software quality requirements and evaluation (SQuaRE). ISO.
- Ministerio de Salud y Protección Social de Colombia. (1999). Resolución 1995 de 1999, por la cual se establecen normas para el manejo de la historia clínica.
- Ministerio de Salud y Protección Social de Colombia. (2019). Resolución 2654 de 2019, por la cual se establecen disposiciones para la telesalud en Colombia.
- Ministerio de Salud y Protección Social de Colombia. (2019). Resolución 3100 de 2019, por la cual se definen los procedimientos y condiciones de inscripción de los prestadores de servicios de salud.
- Paredes, L., Benavides, L., & Sánchez, N. (2017). Guía de recomendación para la selección de un modelo de calidad para la mejora de procesos de software (SPI). *Revista Ciencias Estratégicas*.
- PCI Security Standards Council. (2022). Requisitos y procedimientos de evaluación de seguridad: Estándar de seguridad de datos de la industria de tarjetas de pago (PCI-DSS).
- República de Colombia. (2012). Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. Congreso de la República.
- República de Colombia. (2013). Decreto 1377 de 2013, por el cual se reglamenta parcialmente la Ley 1581 de 2012. Presidencia de la República.